

Memory

AI-Based Phishing and Social Engineering Detection Assistant (PS57)

This is the persistent context file for the project — meant to be loaded by any AI coding tool (Claude Code, Cursor, etc.) at the start of a session, so it doesn't have to be re-explained every time. Companion to [PRD_PhishGuard_PS57.md](#), [ARCHITECTURE_PhishGuard_PS57.md](#), [RULES_PhishGuard_PS57.md](#), [PHASES_PhishGuard_PS57.md](#), and [DESIGN_PhishGuard_PS57.md](#). If any fact here conflicts with one of those docs, the dedicated doc wins — this file is a summary/index, not a replacement.

1. What This Project Is

An AI-based phishing and social engineering detection assistant, built for PS57 (Blockchain & Cybersecurity theme) — the problem statement chosen for NIT Raipur's Internal Hackathon 2026, which is the institute's selection process for Smart India Hackathon 2026.

One-line pitch: Existing tools only catch known-bad links; this catches the psychological manipulation behind an attack — including brand-new, link-free social engineering — and explains *why* in plain language instead of a binary safe/unsafe flag.

Full context: see [PRD_PhishGuard_PS57.md](#) §1–2.

2. Where We Are (update this section as the project moves)

- Team: 6 members confirmed.
 - Registration: due Aug 20, 11:59 PM (Phase 0).
 - Round 1: Idea PPT only, due Aug 22, 11:59 PM — no code required yet.
 - Phase 2 build (if shortlisted): Aug 25–29, per [PHASES_PhishGuard_PS57.md](#).
-

3. Core Technical Decisions (don't relitigate these mid-build)

- **Stack:** Next.js / Node.js, single app, API routes under `/app/api/`. No separate backend service.
- **AI provider:** Gemini or Claude API, structured JSON-only output.
- **Detection approach:** dual-layer — deterministic local heuristics (Levenshtein domain distance, anchor/href mismatch, TLD risk scoring, urgency keyword detection) + LLM reasoning for intent/psychological-pressure analysis.
- **Scoring:** weighted combination, starting point $0.4 \times \text{heuristic} + 0.6 \times \text{LLM}$, tunable after testing against the 3 test cases.
- **Privacy:** PII is anonymized before every LLM call — non-negotiable, see [RULES_PhishGuard_PS57.md §1](#).
- **Demo resilience:** the 3 sample test cases must work with hardcoded, pre-computed responses — no dependency on live network/API during the demo.

Full detail: [ARCHITECTURE_PhishGuard_PS57.md](#).

4. The 3 Test Cases (used everywhere — PPT, build, demo)

1. **Blatant phish:** Fake bank KYC update, urgency keywords, misspelled domain ([sbi-kyc-update.top](#)).
 2. **Sophisticated social engineering:** Polite "HR performance review" email, no links, asks for credentials/attachment. This is the case that proves the LLM layer earns its place — no link exists for heuristics alone to flag.
 3. **Legitimate email:** Real college notification or receipt. Must produce zero false positive — treated as a launch blocker if it fails, not a minor bug.
-

5. Non-Negotiable Build Rules (see [RULES_PhishGuard_PS57.md](#) for full list)

- Keep heuristics, PII anonymization, and LLM calls in separate, independently-testable modules — don't collapse into one function.
- PII anonymization before every LLM call, always.
- No unhandled LLM failures — timeout/error must fall back to heuristic-only scoring, never a blank screen.
- Risk verdicts come from weighted scores, never a single binary signal.

- Stay in Phase 2 scope: no auth, no persistence/database, no homoglyph detection, no multi-language, no Chrome extension — those are Future Scope only.
-

6. Folder Structure (target — see [ARCHITECTURE_PhishGuard_PS57.md](#) §3 for full detail)

/app/api/analyze/route.ts → orchestration only

/app/components/ → Gauge, ThreatBadges, InputPanel, SampleCaseButtons

/lib/heuristics/ → one file per sub-check + index.ts

/lib/llm/ → prompt.ts, client.ts

/lib/piiAnonymizer.ts

/lib/scoringEngine.ts

/lib/protectedBrands.ts

7. Design Language (see [DESIGN_PhishGuard_PS57.md](#) for full spec)

- Calm/clinical palette, not alarmist — one accent color + green/amber/red risk tiers only.
 - Gauge + verdict badge + plain-language explanation must always visually agree — if they don't, it's a scoring bug, treat it as blocking.
 - Same visual language should carry into the PPT (architecture diagram, comparison table) for consistency.
-

8. Known Open Questions / Things Still To Decide

- Final product name (currently placeholder: "PhishGuard" in filenames only, not finalized).
- Exact protected-brands list for domain lookalike detection.
- Final heuristic/LLM scoring weights — placeholder is 0.4/0.6, adjust after running all 3 test cases (Phase 6).
- Who presents which slide / drives the live demo — assign during Phase 7.

9. Judge Questions to Always Be Ready For

- "Why not just use a blocklist?" → proactive/explainable vs. reactive/opaque (PRD §2).
- "What's your false-positive rate?" → weighted scoring design + Case 3 validation (Phases §6).
- "How do you protect user privacy?" → PII anonymization before LLM call (Rules §1, §4).
- "How does domain lookalike detection work?" → Levenshtein distance, already studied — can explain from first principles if asked.